Specification Document

Phase 1: Building Entreprise Infrastructure

Prepared by: SecurinetsENIT

November, 2025

CONTENTS

1 Executive Summary 1

2 Project Goals and Learning Objectives 1

2.1 Prerequisites 1

2.2 Key Takeaways 1

3 Technical Architecture and Environment 2

4 Technical Architecture and Environment 2

5 Active Directory Design and Configuration 3

5.1 Organizational Unit (OU) Structure 3

5.2 Delegation of Control Matrix 3

5.3 Group Policy Objects (GPOs) Strategy 5

6 System and Network Services Configuration 6

7 Network Security and Perimeter Defense 6

8 Security Testing, Validation, and Deliverables 7

8.1 Attack Testing and Infrastructure Validation 7

8.2 Final Product Deliverables 7

9 Project Timeline and Evaluation Schedule 8

1 Executive Summary

This project represents the first phase in establishing a secure, reliable, and fully operational enterprise network infrastructure for **SecurinetsENIT** within a controlled virtualized environment. Its primary objective is to design and deploy an **Active Directory (AD)** domain, configure critical **Windows services** (DNS, LDAP, ADCS, and Kerberos), and implement granular access controls through **Group Policy Objects** (GPOs) and delegation mechanisms. In addition, the project aims to reinforce network security by integrating an **IDS/IPS-based firewall** for perimeter protection.
The implementation will conclude with a **testing** to validate the effectiveness of all deployed controls, supported by **detailed technical documentation** of the entire setup.

2 Project Goals and Learning Objectives

2.1 Prerequisites

The primary prerequisite for this project is a strong motivation to learn and explore new concepts in enterprise IT security and networking.

2.2 Key Takeaways

Successful completion of this project phase will demonstrate proficiency and practical experience in the following areas:

- **Network Fundamentals:** In-depth understanding of network architecture, IP addressing, subnetting, and connectivity testing across virtualized network segments.
- **Active Directory Administration:** Deployment and management of Domain Controllers (DCs), users, groups, Organizational Units (OUs), and Group Policy Objects (GPOs).
- **Enterprise Environment Familiarity:** Hands-on experience with Windows Server 2022 and Windows client systems within a domain-joined enterprise environment.
- **Windows Services Configuration:** Configuration and troubleshooting of critical services such as LDAP, Active Directory Certificate Services (ADCS), and Domain Name System (DNS).

- **Kerberos Authentication:** Comprehensive understanding of the Kerberos authentication protocol, including ticket exchange, encryption mechanisms, and common vulnerabilities.
- **Attack and Defense Techniques:** practical exposure to common attack vectors and implementation of effective mitigation strategies.
- **Perimeter Security Implementation:** Deployment and configuration of an Intrusion Detection and Prevention System (IDS/IPS) using OPNsense and Zenarmor/Suricata for enhanced network defense.

3 Technical Architecture and Environment

The project environment is fully virtualized and hosted on a VMware platform, providing an isolated and controllable setup for deploying and testing enterprise-grade network services. This architecture ensures scalability, ease of snapshot-based recovery, and realistic emulation of a corporate IT infrastructure.

4 Technical Architecture and Environment

The project environment is fully virtualized and hosted on a **VMware** platform, providing an isolated and controllable setup for deploying and testing enterprise-grade network services.

Component	**Role**	**Operating System / Tool**	**Notes**
Domain Controller	Primary Identity and Authentication Server	Windows Server 2022	Hosts AD DS, DNS, ADCS, LDAP, and the Kerberos KDC.
Workstation	Standard Client Endpoint	Windows 10 or 11	Domain-joined client used for testing user access, GPO application, and authentication workflows.
Firewall	Network Security and Traffic Management	OPNsense (with Zenarmor and Suricata)	Provides routing, NAT, firewall, and IDS/IPS capabilities; positioned between external and internal virtual networks.

5 Active Directory Design and Configuration

5.1 Organizational Unit (OU) Structure

The OU structure is designed to logically separate directory objects and facilitate targeted Group Policy Object (GPO) application and delegation of control based on the Principle of Least Privilege (PoLP).

→ `Securinetsenit.local` (Root Domain)

- `_SERVICE_ACCOUNTS`
- `COMPUTERS`
  - `Workstations`
  - `Servers`
- `USERS`
  - `Admins`
    - `DomainAdmins`
    - `Technical Team`
  - `Departments`
    - `Finance`
    - `Marketing`
    - `IT`

5.2 Delegation of Control Matrix

Control is delegated to specific security groups (rather than individual users) at the appropriate OU level, ensuring accountability and maintainability. The following table outlines the delegation design.

Group / Role	Target OU(s)	Permissions Granted (Delegated Control)	Permissions Denied (Implicitly)
DomainAdmins	Root Domain, All OUs	Full administrative control, including Domain Controller management, schema modification, and GPO linking at the domain level.	No administrative restrictions within the lab environment.
Technical Team	`COMPUTERS/Servers`, `USERS/Departments/IT`	Manage server objects, reset computer accounts, apply GPOs for IT systems, and perform routine AD maintenance.	Modifying domain-level policies, altering admin accounts, or schema changes.
Finance Department	`USERS/Departments/Finance`	Read and write access to financial shared folders, logon rights to accounting servers, and use of department-specific GPOs.	Installing software, modifying network configurations, or accessing Marketing/IT data.
Marketing Department	`USERS/Departments/Marketing`	Read/write access to marketing drives and collaboration tools, use of standard GPO-based security settings.	Accessing Finance or IT systems, modifying system settings, or installing unauthorized software.
IT Department	`USERS/Departments/IT`	Elevated permissions to maintain workstations, manage network configurations, and assist with technical troubleshooting.	Schema modifications, domain-level GPO linking, or management of DomainAdmins.
Workstations OU Users	`COMPUTERS/Workstations`	Standard user permissions for business operations and workstation logon.	Any administrative privileges, software installation, or system configuration changes.

5.3 Group Policy Objects (GPOs) Strategy

GPOs will be linked to the appropriate Organizational Units (OUs) to enforce security baselines, ensure consistent configuration, and maintain compliance across the environment. Each GPO targets a specific OU or group of users and computers.

GPO Name	Link Location	Target	Key Settings (Example)
Default Domain Policy	Domain Root	All Users/-Computers	**Password Policy:** Enforce complexity, Min Length (14 chars), Max Age (45 days), Lockout Threshold (5 attempts). **Kerberos Policy:** Max ticket lifetime (10 hours).
User - Standard Security	`USERS/Departments`	Finance, Marketing, IT	Enforce screen lock after 10 mins idle, disable Control Panel access (Finance/Marketing), apply desktop background (branding), restrict command-line tools for non-IT users.
Computer - Hardening	`COMPUTERS/Workstations`	Domain-joined Computers	Enable Windows Firewall (block unused inbound ports), disable guest accounts, restrict USB auto-run, enforce secure channel signing, remove local admin privileges.
Server - Security Baseline	`COMPUTERS/Servers`	Domain and Service Servers	Audit object access, disable anonymous SID enumeration, enforce NTLMv2, restrict PowerShell execution, enable NTP sync with DC.
IT Admin Tools Policy	`USERS/Admins/Technical Team`	IT Administrators	Allow PowerShell execution, enable remote management, disable sleep-/hibernation, enforce event log retention, enable RSAT tools.
Finance Application Control	`USERS/Departments/Finance`	Finance Users	Apply AppLocker/SRP rules (signed executables only), disable removable drives, enforce restricted access to financial shares.
Marketing Environment Policy	`USERS/Departments/Marketing`	Marketing Users	Enforce browser proxy settings, set homepage, restrict registry editing, disable time zone and network configuration changes.
IT Workstations Policy	`USERS/Departments/IT`	IT Staff Systems	Enable developer tools (Wireshark, Nmap), allow lab PowerShell scripts, enable PowerShell and privilege escalation auditing.

6 System and Network Services Configuration

This phase focuses on core AD services crucial for the secure operation and future attack validation steps.

1. **DNS & DHCP:** Configure the Domain Controller to act as the authoritative DNS server for the domain. Ensure all client VMs are properly utilizing the DC for DNS resolution.
2. **LDAP:** Verify secure LDAP (LDAPS) functionality.
3. **AD Certificate Services (ADCS):** Install and configure a basic Enterprise Certificate Authority (CA) on the DC.
4. **Kerberos Authentication:** Verify correct ticket generation (TGT and TGS) using command-line tools (`klist`). Document SPN requirements for later testing.

7 Network Security and Perimeter Defense

1. **Firewall (OpenSense) Setup:** Configure the firewall VM to separate the internal AD network from the external simulated network/Internet access.
2. **Zenarmor/Suricata IDS/IPS Configuration:**
   - Enable and configure Zenarmor/Suricata for IDS mode initially (monitoring).
   - Test baseline alerts by simulating basic unauthorized traffic.
   - Switch to IPS mode for active blocking and validate that configured AD attacks are blocked.

You are encouraged to research, evaluate, and propose additional or alternative network security tools to complement the baseline IDS/IPS deployment.

8 Security Testing, Validation, and Deliverables

8.1 Attack Testing and Infrastructure Validation

This phase ensures the defense mechanisms built in the AD and Firewall are effective.

- **Credential Attacks:**
  - **AS-REP Roasting:** Targeting user accounts where pre-authentication is intentionally disabled (lab only).
  - **Kerberoasting:** Exploiting weak SPNs (Service Principal Name) against service accounts.
  - **Password Spraying/Brute Force:** Validate Account Lockout policies.
- **Access Control Validation:** Attempt delegated tasks and verify restrictions.
- **GPO Enforcement Test:** Verify GPOs apply correctly to Workstation VM.
- **Firewall/IPS Test:** Attempt port scanning and simple exploits to validate logging/blocking.

8.2 Final Product Deliverables

1. **Full Connected Network:** All three VMs configured per spec.
2. **Firewall Configuration:** OpenSense with Suricata/Zenarmor configured and operational.
3. **Presentation:** Summary of design decisions, implementation steps, controls and findings.
4. **Full Documentation (GitBook/Blog/GitHub):**
   - Step-by-step installation and configuration.
   - Complete AD Design documentation (OU Structure, Groups, Delegation).
   - GPO implementation details and screenshots.
   - Summary of Kerberos concepts and attack simulation results.
   - References.

9 Project Timeline and Evaluation Schedule

Phase	Duration	Tasks	Evaluation Criteria (Weekly)
Phase 1: Setup and Connectivity	1 Week	Download ISOs, configure VMs, install OS, verify connectivity.	Proof: VMs successfully ping each other and resolve DNS.
Phase 2: Core AD & Services	1–2 Weeks	Promote Domain Controller, design OU structure, create users/groups, configure LDAP/DNS/GPOs.	Demo: OU structure, delegated rights, GPO enforcement.
Phase 3: Perimeter Defense & Hardening	1 Week	Install OPNsense, configure WAN/LAN, deploy Zenarmor/-Suricata in IDS mode and tune rules.	Report: Firewall rules, IDS logs, and tuning notes.
Phase 4: Advanced AD & Kerberos	1–2 Weeks	Research Kerberos, configure ADCS, register SPNs and prepare Kerberoasting lab scenarios.	Quiz/Demo: Kerberos flow explanation and SPN documentation.
Phase 5: Attack Testing & Final Deliverables	1 Week	Execute test scenarios, validate detections and blocks, finalize documentation and presentation.	Presentation: Test results, logs, mitigations, and completed documentation.
Total Project Duration: $\approx$ 8 Weeks			